Vendor Viewpoint

Governance, Risk Management & Compliance Insight

MetricStream

More than a Platform . . . an Integrated GRC Architecture for the Enterprise

Executive Summary

Business is complex. Keeping complexity and change in sync is a significant challenge for boards, executives, and governance, risk management, and compliance professionals (GRC) throughout the business. The organization requires complete situational awareness of GRC across operations, processes, relationships, systems, and data to see the big picture of risk and its impact on organization performance and strategy. The goal should be to enable a GRC architecture that effectively reconciles organization strategy, process, information, and technology into a federated architecture model. MetricStream is a vendor in the GRC market that GRC 20/20 has closely evaluated and monitored over years. MetricStream is a leader in the path of evolution from the GRC platforms of the past to a truly integrated architecture that connects into the fabric of business to operationalize GRC and deliver GRC intelligence. Its roadmap shows readiness for GRC 3.0 as defined by GRC 20/20. The integration of community, thought leadership, content, and focused applets further extend MetricStream's value to organizations and its role as a leader in the GRC market.

October 2013

Michael Rasmussen, Chief GRC Pundit

Table of Contents

Organizations Encumbered by Complexity 3

Why not see BOTH the forest and the trees? 4

Moving Beyond the GRC Platform to GRC Architecture 5

MetricStream: Delivering Enterprise GRC Architecture 6

The Value of MetricStream's GRC Architecture 6

The Capabilities of MetricStream's GRC Architecture 7

Considerations About Engaging MetricStream 9

GRC 20/20's Final Perspective 10

About 11

GRC 20/20, LLC 11

Michael Rasmussen, Chief GRC Pundit 11

Research Methodology 11

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

Organizations Encumbered by Complexity

Business is complex. Exponential change in regulations, globalization, distributed operations, processes, competitive velocity, business relationships, technology, and business data encumbers organizations of all sizes. Keeping complexity and change in sync is a significant challenge for boards, executives, and governance, risk management, and compliance professionals (GRC) throughout the business.

Complexity of business breeds an element of chaos and uncertainty as the organization is in a constant state of metamorphosis. Consider that organizations are:

- **Dynamic:** Organizations are in a constant state of flux. Distributed business operations and relationships are growing and changing as the organization attempts to remain competitive. Risk environments that organizations have to monitor span regulatory, geo-political, market, credit, and operational risks. Regulations continue to grow and have more than doubled in some industries in the past few years (penalties and fines continue to grow significantly). Managing change to risk, regulatory, and business environments have encumbered organizations.

- **Distributed:** Organizations have distributed operations complicated by a web of global supplier, agent, business partner, and client relationships. Traditional brick and mortar business is a thing of the past: physical buildings and conventional employees no longer define the organization. An interconnected mesh of relationships and transactions redefine business boundaries. Complexity grows as interconnected relationships, processes, and systems nest themselves in intricacy, such as deep, multi-layered supply chains. The challenge with extended enterprise relationships is that change is exponential. Not only is the organization dealing with constant change in its own operations, each individual relationship is dealing with change and continues downstream. This brings risk exposure to the organization that sits in the shoes of its extended relationships.

- **Disrupted:** The intersection of distributed and dynamic business brings disruption. Change combined with complexity in distributed operations/relationships means the organization is easily disrupted in the context of GRC. The explosion of data and transactions has brought on the era of "Big Data." Organizations manage high volumes of structured and unstructured data across multiple systems, processes, and relationships as they attempt to unravel the entire picture of risk in the context of performance. Velocity, variety, and volume of data is overwhelming – disrupting the organization and slowing it down at a time when it needs to be agile.

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

The bottom line: The organization requires complete situational awareness of GRC across operations, processes, relationships, systems, and data to see the big picture of risk and its impact on organization performance and strategy. GRC cannot be managed in isolation. That is what fails (as past crisis events and corporate debacles have repeatedly shown). Disconnected and distributed systems of the past catch the organization off guard to risk. Dissociated data, systems, and processes leaves the organization with fragments of truth that fail to see the big picture of performance, risk, and compliance across the enterprise. GRC fails when risk issues are addressed as a system of parts that do not integrate and work as a collective whole. GRC is about the interactions and relationships of cause and effect across strategy, process, transactions, information, and technology supporting the business and requires a GRC architecture approach. Complexity of business and intricacy and interconnectedness of GRC data requires that the organization have an integrated approach to business systems, data, and GRC. Distributed, dynamic, and disrupted business requires the organization to take a strategic approach to GRC architecture.

Why not see BOTH the forest and the trees?

The individual components of GRC -- governance, risk management, and compliance -- are a necessary and intricate part of business. GRC is not optional: every organization has some approach to GRC from the ad hoc to the agile. The primary directive of a mature GRC program is to deliver effectiveness, efficiency, and agility to the business in managing the interrelationship of performance, risk, and compliance. This requires a strategic approach that connects the enterprise, business units, processes, transactions, and information to enable transparency, discipline, and control of the ecosystem of business and operational activities.

GRC relationships are non-linear. In a linear system effect is proportional with cause, in the non-linear world of business and GRC it is exponential. If we fail to see the interconnections of risk on the non-linear world of business the result is often exponential to unpredictable.

To maintain integrity, and execute on strategy, the organization has to be able to see the individual area of risk (the tree) as well as the interconnectedness of risks (the forest). The organization does not need a GRC platform that simply manages workflow, content and tasks. The organization needs GRC architecture to provide . . .

- **Context.** The organization needs to make business decisions with a full view of risk aligned to objectives. This requires an integration of risk with decision-making.

- **Alignment.** The organization needs to align business strategy and objectives and be able to identify and capitalize on opportunities through strong risk management practices while reducing overall risk exposure.

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

- **Awareness.** The organization needs enterprise-wide visibility and control across its own operations and the extended enterprise. This requires an ability to see the complex interrelationships of operational, legal, regulatory, finance risks in the context of strategy, performance, and objectives.

- **Value.** The organization has to protect shareholder value and the brand of the organization while controlling costs and reducing loss.

GRC is an integration of governance, risk management, and compliance in the context of business performance, strategy, and objectives. The official definition of GRC is:

> *A capability to reliably achieve objectives [governance] while addressing uncertainty [risk management] and acting with integrity [compliance].*[1]

The reliable achievement of objectives is governance, understanding and addressing uncertainty is risk management, and acting with integrity is compliance. All three of these provide a natural flow. Governance provides strategy and objectives that deliver the context for risk management. Risk management, in turn, aims to comprehend and predict uncertainty and set boundaries and expectations so the organization can reliably achieve those objectives. Compliance then ensures that the organization stays within the boundaries set by risk management as it aims to reliably achieve objectives. GRC is part of every business whether it is called GRC or something else.

Moving Beyond the GRC Platform to GRC Architecture

The core of GRC is about operationalizing GRC across the fabric of business strategy and operations – seamlessly, agilely and non-invasively. This involves employee engagement in GRC that is simple, mobile, and easy to use at the frontline of the business. It is about leveraging and harmonizing existing data and systems that deliver results in focused areas but now need to feed into the bigger picture of enterprise transparency in the context of distributed and dynamic business.

GRC has been approached tactically and not strategically. What is often missing is a level of integration that provides a central nervous system that connects everything and makes GRC part of business in the context of business. Organizations need to move beyond the concept of a GRC platform and focus on an integrated view of GRC data and systems through a GRC architecture that is a cohesive part of the broader business fabric of the organization. Historically, organizations suffered when GRC did not connect the dots and provide context to business analytics, performance, objectives and strategy. The goal should be to enable a GRC architecture that effectively reconciles organization

1 This is the only definition for GRC found in a publicly vetted and available standard, the OCEG GRC Capability Model.

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

strategy, process, information, and technology into a federated architecture model.

GRC architecture allows for diversity while still providing integration, discipline, and consistency. The organization needs a GRC architecture of process, technology, and information that integrates to provide optimal alignment and value to the business. "Orchestration" of the diverse elements of GRC through an integrated architecture enables agility. GRC architecture delivers the ability to effectively mitigate risk, address requirements, satisfy auditors, achieve human and financial efficiency, and meet the demands of a changing business environment that requires agility. GRC, when designed properly, should achieve better-performing processes that use integrated and reliable information to enable less costly, more flexible business environment.

MetricStream: Delivering Enterprise GRC Architecture

MetricStream is a vendor in the GRC market that GRC 20/20 has closely evaluated and monitored over years. While there are many capable GRC solutions on the market today, MetricStream provides one of the most comprehensive set of GRC capabilities in the context of business. This has not been easy to achieve and at times has been a bumpy road for MetricStream, but it has continued to invest in R&D to enhance its technology consistently year after year. GRC 20/20 has monitored MetricStream in the market and at times has seen MetricStream stretch itself to capacity in client projects to take on challenging and sophisticated implementations. In the end this has paid off with a comprehensive GRC architecture. In fact, MetricStream is a leader on the path of evolution from the GRC platforms of the past to a truly integrated architecture that connects into the fabric of business to operationalize GRC and deliver GRC intelligence.

The Value of MetricStream's GRC Architecture

GRC 20/20 measures GRC architecture value around the elements of efficiency, effectiveness and agility. Through ongoing research, interviews, and interactions with MetricStream clients, large enterprises as well as mid-sized companies, GRC 20/20 finds consistency in value that MetricStream delivers on:

- **Effectiveness.** MetricStream implementations, particularly in the past two years, achieve effectiveness in risk, control, compliance, audit, policy, and business process. This is delivered through an architecture that manages the design and operational effectiveness of controls to mitigate risk, achieve performance, (map KRIs and KPIs) protect integrity of the organization, and meet regulatory requirements. Clients validate MetricStream's GRC effectiveness by stating they have stronger business processes that are operating within the controls and policies set by the organization and provide greater reliability of information to auditors and regulators. Effectiveness of the MetricStream implementations is measured both in design

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

and the operation of their GRC architecture as it integrates and supports the broader business.

- **Efficiency.** Clients report that MetricStream provides efficiency and savings in both human and financial capital resources. GRC processes, supported by MetricStream, reduce operational costs through automation, harmonization and rationalization, particularly those that take significant time consolidating and reconciling information to manage, analyze, report, and mitigate risk and meet compliance requirements. MetricStream achieves efficiency through a measurable reduction in human and financial capital resources needed to address GRC in the context of business operations.

- **Agility.** Through a federated and flexible GRC data model, MetricStream enables their clients to deliver business agility as they are able to respond rapidly to changes in the internal business environment (e.g., employees, business relationships, operational risks, mergers and acquisitions) as well as the external environment (e.g., economic risk, new laws and regulations, social media). Further, clients report agility value with MetricStream by being more responsive to events and issues so that they can identify and react quickly to control failures and weaknesses, non-compliance, and adverse events in a timely manner so that action can be taken and loss is contained.

The Capabilities of MetricStream's GRC Architecture

GRC 20/20 finds that MetricStream has delivered one of the widest arrays of integrated and configurable GRC applications on a common architecture available on the market. The MetricStream solution delivers a wide array of capabilities that include:

- **Functional applications.** The range of MetricStream solutions span the areas of risk management, policy management, compliance management, audit management, environmental health & safety, environmental monitoring, IT GRC/security management, 3rd party GRC (vendor/supplier), product quality and compliance, legal GRC (e.g., matter management), contract management, and others. This provides the most comprehensive array of GRC applications available from any one vendor in the GRC market.

- **Issue specific applications.** In addition to functional applications, the MetricStream solution has a range of targeted applications (or more appropriately called Zaplets through MetricStream's Zaplet partner ecosystem) that address very specific points of pain like conflict minerals compliance, social media risks and compliance, gift and entertainment compliance, conflict of interest and more.

- **Industry specific GRC applications.** MetricStream has also been thorough at identifying

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

industry specific needs and delivering solutions that meet the unique needs of specific industries such as banking, retail, insurance, life sciences, consumer packaged goods, food and beverage, and manufacturing.

- **Operationalizing GRC.** MetricStream's approach to GRC architecture involves operationalizing GRC by integrating business applications, processes, and data. They provide the integration that enables GRC to interact with business systems such as business intelligence, performance, and ERP environment. This provides real-time insight into business decisions, operational intelligence, and monitoring in the context of risk and compliance. Through this MetricStream delivers automated controls within the transaction environments. MetricStream provides an architecture that integrates with a range of applications and interfaces to share data between them to provide holistic awareness of risk in the context of business.

- **Integration of content.** MetricStream has recently significantly advanced their solution to delivery of content from knowledge/content providers through their GRC architecture. This includes content around changing regulations, risks, industry and geopolitical events. Content is tagged so it can be properly routed to the right subject matter expert to establish workflow and tasks for review and analysis. Standardized formats for measuring business impact and review of existing processes, policies, and controls can take place.

- **Analytics with contextual awareness.** Through an array of risk and performance analytical capabilities organizations use MetricStream to gain a complete view of what is happening: this is what GRC 20/20 refers to as 360° GRC contextual awareness. MetricStream allows for advanced analytics of risk and compliance in a way that it is monitored and understood in the course of business operations, changing risks and regulations, and interactions. Delivery of GRC contextual awareness is built on MetricStream GRC architecture that operates as a central nervous system to capture signals found in processes, data, and transactions as well as changing risks and regulations for interpretation, analysis, and holistic awareness of risk in the context of business.

- **Mobility.** MetricStream has recently taken a lead in GRC mobility with the widest array of GRC mobile apps covering audit, risk/compliance assessment, investigations, policy & training, and more. MetricStream has embraced GRC through mobile technology on tablets and other devices. Issue reporting is readily done through mobile devices. Tablets deliver policies, training, and other interactive content to employees, particularly those without desktop workstation access; or they can be used as a mobile policy and training kiosk for a group of employees. Mobile devices can be used to conduct investigations, audits and risk/compliance assessments. The ability to record GPS coordinates, pictures and video right into MetricStream mobile GRC applications make these processes more efficient and effective.

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

- **EcoSystem of GRC.** What is particularly interesting about MetricStream is that they understand the breadth and depth of GRC and that it is more than a central platform. Through MetricStream's Zaplet platform organizations can custom configure solutions to integrate into the MetricStream GRC architecture or operate standalone to address specific needs. Most consulting and system integration firms have built GRC practices with competency in implementing and supporting MetricStream. With ComplianceOnline MetricStream delivers a wide range of GRC education and training that is agnostic to MetricStream. With GRCIntelligence.com MetricStream is now delivering a portal of integrated GRC content through content/knowledge providers that spans regulatory, policy, risk, and control content that can easily be accessed and used within MetricStream's breadth of solutions and core GRC architecture.

- **Community.** MetricStream is also showing thought leadership in establishing communities where individuals as well as organizations can contribute, learn and grow. Its customer summits, customer special interest groups (SIGs), industry roundtables as well as deep engagements with influential industry bodies and associations strongly bonds GRC practitioners with MetricStream. This includes the educational and training world of MetricStream University, ComplianceOnline.com as well as interactive content through ThriveOnRisk.com and GRC-TV.

Considerations About Engaging MetricStream

Every solution has its strengths and weaknesses, and is not the perfect fit for all organizations in all situations. While GRC 20/20 has identified a lot of very positive things about MetricStream and the breadth and depth of what they are delivering in the GRC space – readers should not see this as a complete and unquestionable rubber stamp on MetricStream.

MetricStream is delivering a broad array of GRC solutions. No other vendor is executing as broadly across issues and industries as MetricStream currently is by way of new customer acquisition as well as expansions and extensions of current installations. MetricStream has more answers to more GRC problems than any GRC solution available. However, this does not mean they are necessarily the best at every aspect of everything they offer. Some modules in other GRC platforms may have more advanced features or be easier to use in certain cases. MetricStream has a lot of depth to their GRC offerings but depth often comes with complexity and the solution is not always intuitive.

MetricStream at times has stretched itself in projects by engaging for more than they readily offered – though they have always pulled through by collaborating with customers, leveraging its pool of domain experts, and grew their platform to the point that it has a broad array of capabilities. MetricStream has also stretched itself in customizations of their platform that made upgrades difficult for some clients. However, through continued enhancements in their platform architecture

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

and AppStudio, MetricStream appears to have left this behind as the last two years of GRC 20/20 interactions has shown continuous improvement in this area and it is rare that GRC 20/20 sees complaints or issues on this in regards to MetricStream anymore.

The point is that any organization engaging a GRC solution provider, including MetricStream, needs to do their homework to ensure that they clearly understand what it is they need and are engaging the right solution provider to deliver on those needs.

GRC 20/20's Final Perspective . . .

GRC 20/20 finds that MetricStream has delivered a comprehensive integrated suite of GRC solutions available on the market today. These solutions are enhanced through MetricStream's ability to integrate with other systems and the fabric of business operations and applications. This enables MetricStream to be a leader in not just being a GRC platform but providing an integrated GRC architecture that is part of business and not just a band-aid to cover the pain of risk and compliance demands. While MetricStream delivers on depth and breadth of GRC, it also has shown flexibility in solving very specific GRC problems and requirements for organizations. Its roadmap shows readiness for GRC 3.0 as defined by GRC 20/20. MetricStream is worthy of consideration for a range of GRC challenges. The integration of community, thought leadership, content, and focused applets further extend MetricStream's value to organizations and its role as a leader in the GRC market.

©2013 GRC 20/20, LLC; Licensed to MetricStream for Redistribution

About . . .

GRC 20/20, LLC

GRC 20/20 provides independent and objective research and analysis on topics related to governance, risk management and compliance (GRC). Our analysts bring real-world expertise, independence, creativity and objectivity to help organizations understand and apply strategies and technology to meet their GRC challenges. Whether it is focused on a specific issue or an enterprise-wide GRC strategy, clients seek GRC 20/20 analyst advice in achieving sustainable and pragmatic innovation. GRC 20/20 advises the entire ecosystem of GRC solution buyers, solution providers and vendor clients. We serve the needs of organizations that seek insight, guidance and advice in dealing with a dizzying array of disruptive business models and technologies.

Michael Rasmussen, Chief GRC Pundit

Michael Rasmussen is an internationally recognized pundit on governance, risk management and compliance (GRC) — with specific expertise on the topics of corporate compliance, business ethics, policy management and corporate culture. With 18+ years of experience, Michael helps organizations improve GRC processes and choose technologies that are effective, efficient and agile. He is a sought-after keynote speaker, author and advisor and is noted as the Father of GRC — being the first to define and model the GRC market in 2002.



Research Methodology

In this report, GRC 20/20 Research, LLC conducted qualitative research and analysis through interviews with GRC professionals in Fortune 1000 organizations along with briefings from MetricStream. The focus of these interviews and briefings were to identify drivers and trends influencing GRC processes and technology in the market with a particular focus on MetricStreams capabilities and value.

All of GRC 20/20 Research is based on quantitative and/or qualitative research. The foundation for GRC 20/20 comes through interactions with organizations across industries and the GRC professional roles within those organizations. The GRC roles within these organizations span the context of audit, corporate compliance, corporate social responsibility, ethics, finance, health and safety, human resources, information technology, legal, quality, risk management, security and vendors and supply-chain professionals. These interactions provide the foundation GRC 20/20 uses to interact with GRC solution providers through briefings to understand their products and strategy to address the immediate and forthcoming needs of GRC professionals within organizations. GRC 20/20 collects and gathers data through phone interviews, email interactions, in-person advisory and surveys. As part of this process, GRC 20/20 collects market information and data on the solution providers and their offerings to size, forecast and trend the GRC market as a whole along with its various segments. All of this is supported by analyst professional experience and years of insight and experience analyzing GRC processes and the role of GRC technology and solutions to make them more effective, efficient and agile to the needs of organizations today.

© 2013 GRC 20/20 Research, LLC and/or its affiliates. All rights reserved. This publication may not be reproduced or distributed in any form without GRC 20/20's prior written permission. The information contained in this publication has been obtained from sources believed to be reliable. GRC 20/20 disclaims all warranties as to the accuracy, completeness or adequacy of such information and shall have no liability for errors, omissions or inadequacies in such information. This publication consists of the opinions of GRC 20/20's research organization and should not be construed as statements of fact. The opinions expressed herein are subject to change without notice. Although GRC 20/20 research may include a discussion of related legal issues, GRC 20/20 does not provide legal advice or services and its research should not be construed or used as such.

4948 Bayfield Drive
Waterford, WI 53185 USA
+1.888.365.4560
info@grc2020.com
www.grc2020.com